database scheme inherits full permissions to alter the tables and other objects in that database. The *principle of least authority* says that you should only grant users and processes the least permissions that they need to get their job done and no more. Your API does not ever need to drop database tables, so you should not grant it the ability to do so. Changing the permissions will not prevent SQL injection attacks, but it means that if an SQL injection attack is ever found then the consequences will be contained to only those actions you have explicitly allowed.

> **TIP** The ***principle of least authority*** (POLA), also known as the ***principle of least privilege***, says that all users and processes in a system should be given only those permissions that they need to do their job – no more, and no less.

To reduce the permissions that your API runs with, you could try and remove permissions that you do not need (using the SQL `REVOKE` command). This runs the risk that you might accidentally forget to revoke some powerful permissions. A safer alternative is to create a new user and only grant it exactly the permissions that it needs. To do this we can use the SQL standard `CREATE USER` and `GRANT` commands, as shown in listing 2.6. Open the schema.sql file that you created earlier in your text editor and add the commands shown in the listing to the bottom of the file. The listing first creates a new database user and then grants it just the ability to perform `SELECT` and `INSERT` statements on our two database tables.

Listing 2.7 Creating a restricted database user